

601.445/645

Practical Cryptographic Systems

Symmetric Cryptography II

Instructor: Matthew Green

Housekeeping

- **Assignment 1 is out**
 - On the website, under “Schedule”
 - Part 0 is due this Friday
- I made some more changes to the website
 - There is reading! (More coming next week.)
 - ***We have a quiz on Monday!***

Chapter 5

Symmetric encryption and authentication

The most basic function of cryptography is to ensure confidentiality and authenticity of messages that are sent over a hostile communications channel. In the most common setting, this is done using *symmetric encryption*: this refers to the setting where both sender and receiver share the same key. Symmetric primitives tend to be preferred for most data protection, simply because they tend to be more efficient than alternatives like public-key cryptography. In this chapter, we'll discuss the three most common symmetric cryptographic functions: encryption (and *encipherment*), for protecting message confidentiality; message authentication (MACs) for protecting the authenticity of data; and *authenticated encryption* which combines the protections offered by both of those primitives.

In this chapter we'll confine ourselves to discussing these *keyed* primitives. However, any discussion of symmetric cryptography would be incomplete if we did not discuss hash functions. Since that's an intricate topic, we'll discuss those in Chapter 6.

5.1 High-level recommendations

Many cryptography books choose to dive into the weeds of symmetric encryption, starting with block and stream ciphers as well as a variety of legacy modes that you should never use. For completeness, I'll also cover to those details a bit later in this chapter. But sometimes you just need to encrypt something! The question you might have right off the bat is: *what tool should I use to do that?* I'm going to take this opportunity to answer that question first.

News

News

Hey there! You are using WhatsApp: Enumerating Three Billion Accounts for Security and Privacy

Gabriel K. Gegenhuber (University of Vienna, Faculty of Computer Science and UniVie Doctoral School Computer Science), Philipp E. Frenzel (SBA Research), Maximilian Günther (University of Vienna, Faculty of Computer Science), Johanna Ullrich (University of Vienna, Faculty of Computer Science), Aljosha Judmayer (University of Vienna, Faculty of Computer Science)

INSIGHTS | AUGUST 5, 2026

The Largest Hardware Wallet Exploit of 2026: Inside the USD 116 Million Coldcard Hack

 TRM Team

News

The vulnerability

The attack stemmed from a flaw in the Coldcard hardware wallet. Firmware version 4.0.1, released in March 2021, contained a bug that caused some devices to generate wallet seeds with significantly weaker randomness than intended. As a result, wallets created on affected firmware could have private keys that were vulnerable to brute-force attacks.

Updating the firmware fixes the issue for future wallet creation but does not protect wallets whose seeds were generated under the vulnerable firmware. Users who created wallets on affected devices must generate a new seed and transfer their funds to a new wallet.

News

COLDCARD firmware contains an RNG integration error that causes `ngu.random` to use MicroPython's deterministic Yasmarang fallback instead of the STM32 hardware RNG.

The [production board configuration](#) defines `MICROPY_HW_ENABLE_RNG` as zero because COLDCARD [provides a separate hardware-RNG wrapper](#). Libngu [incorrectly checks whether that macro is defined rather than whether it is enabled](#). The build therefore succeeds, and libngu binds to MicroPython's `rng_get()`. With the macro set to zero, [that function is a Yasmarang software generator initialized from the MCU UID and timer registers](#)

News Russian Hackers Are Silently Reading Your WhatsApp Messages Right Now

By Mauven MacLeod · 10 March 2026

♡ 21

Hello, Mauven here.

Yesterday, the Netherlands' two principal intelligence agencies issued a formal public warning. The AIVD, their domestic security service, and the MIVD, their military intelligence counterpart, confirmed that Russian state-sponsored hackers are running what they describe as a large-scale global campaign to compromise Signal and WhatsApp accounts.

Targets include government officials, military personnel, diplomats, and journalists. Dutch government employees have already been affected. Sensitive information has likely already been accessed.

I want to explain precisely why this matters to your small business.

The Attack Does Not Break the Encryption

This is the most important thing to understand first.

Signal and WhatsApp have robust [end-to-end encryption](#). That encryption has not been broken. The apps

Method Two: The Silent Linked Device

This one is considerably more insidious, because the victim never loses access to their account.

Both Signal and WhatsApp support a legitimate feature allowing users to link their account to multiple devices: a computer, a tablet, a second phone. On WhatsApp, this is called Linked Devices. The process normally requires scanning a QR code.

Attackers send targets a QR code or link disguised as a group invitation, a security verification prompt, or a resource from the app's official website. When the target scans it, they unknowingly link the attacker's device to their account.

The target continues using WhatsApp normally. Their old messages are still there. Nothing appears to have changed. Meanwhile, the attacker's device is silently receiving every new message sent to or from that account, in real time, potentially indefinitely.

Germany's BSI advisory notes that Signal lists all linked devices under Settings, but that users rarely check this. That is a reasonable observation: most people have never opened that menu in their lives.

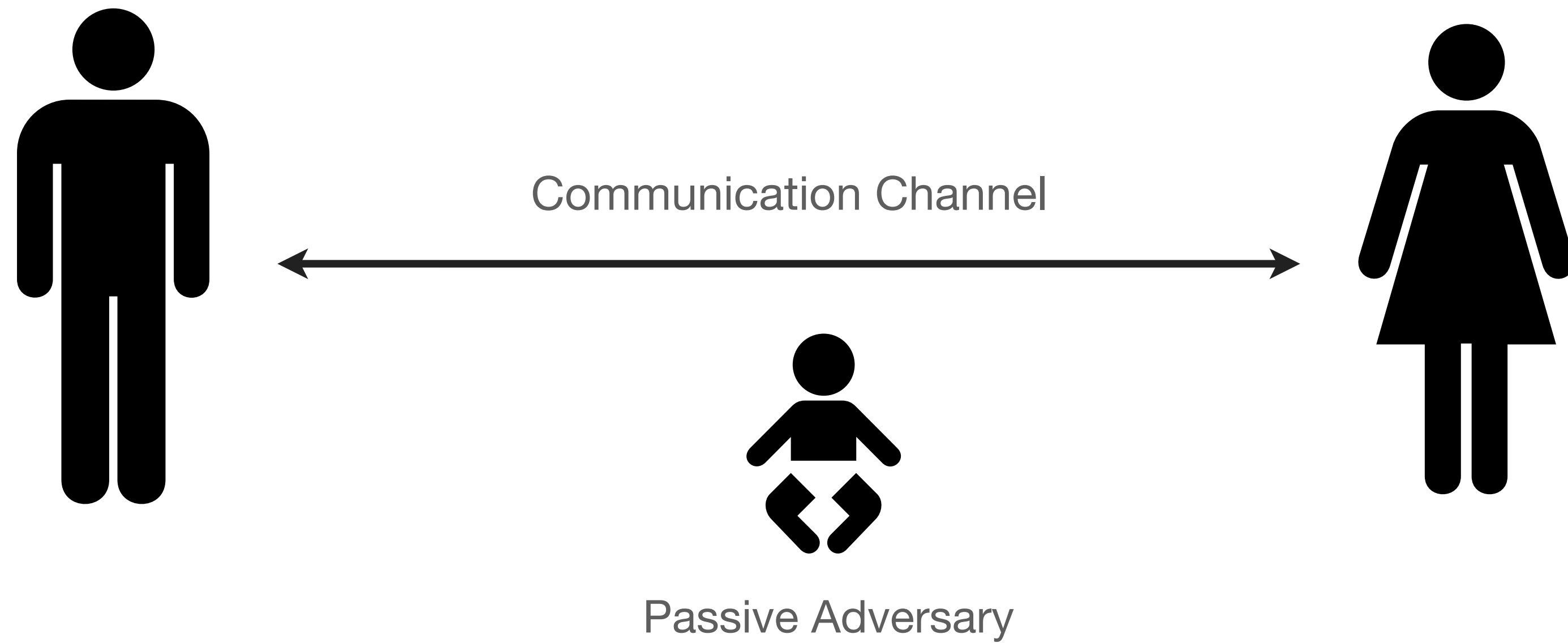
Review

- Last time:
 - We started with classical cryptography: shift, substitution and Vigenere
 - We discussed “key spaces” and how these ciphers fail
 - We introduced Baudot code and the XOR function, Vernam’s cipher
 - We started to talk about One Time Ciphers...

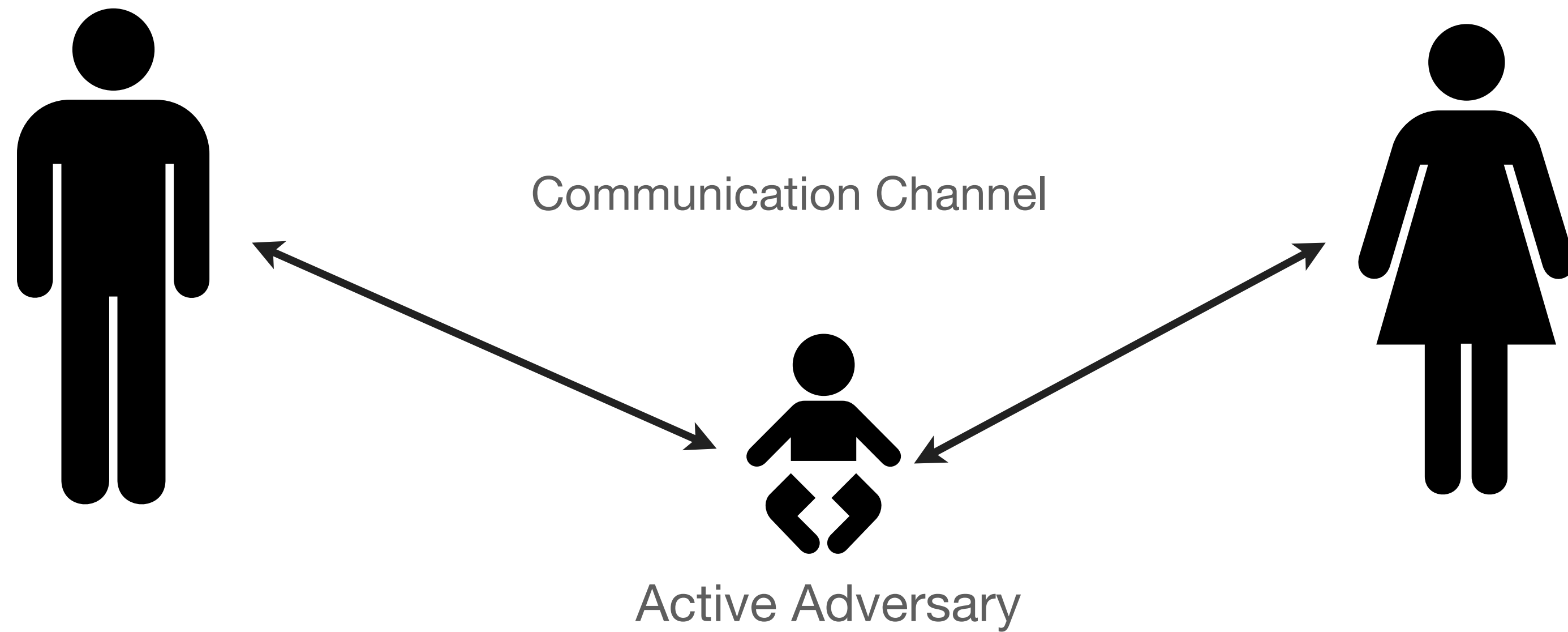
Communication Model



Communication Model



Communication Model



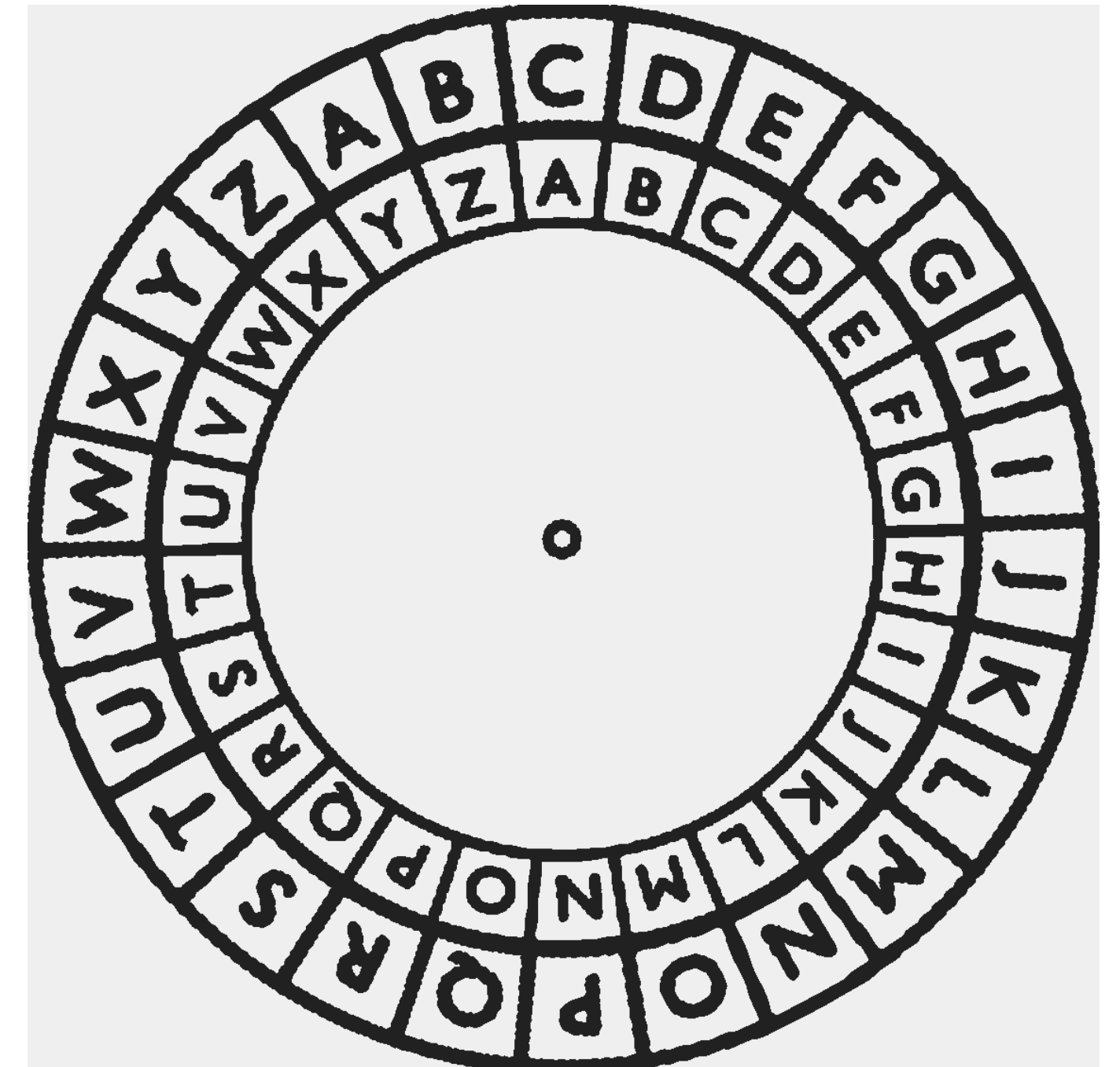
Shift (“Caesar”) cipher

- Key is a “shift value” (0 through 25)
- We take a plaintext and “shift” each letter through the alphabet:

Example, key = 10.

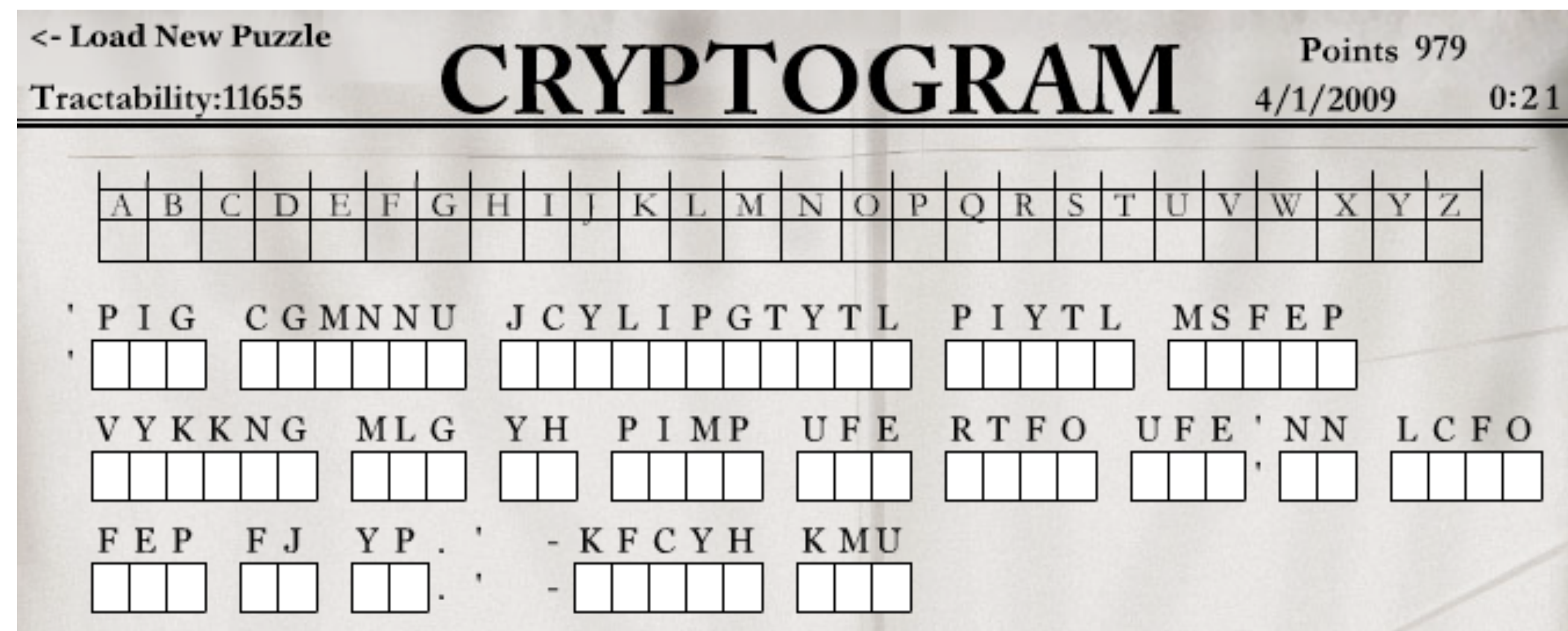
A T T A C K

K D D K M U



Substitution cipher

- Shift cipher has a small key space
 - This means it is vulnerable to “brute force attack”
- *We need a cipher with a larger set of possible keys*
- One solution is the substitution cipher



How many keys in an (alphabetic) substitution cipher?

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
O	J	Z	E	R	K	U	A	S	B	P	W	L	H	M	X	V	Q	G	F	I	D	Y	C	T	N

Figure 2.1: Example key for a simple substitution cipher.

How many keys in an (alphabetic) substitution cipher?

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
O	J	Z	E	R	K	U	A	S	B	P	W	L	H	M	X	V	Q	G	F	I	D	Y	C	T	N

Figure 2.1: Example key for a simple substitution cipher.

$$\text{\#keys} = 26 * 25 * 24 * \dots * 2 * 1$$

$$= 26! = 403 \text{ trillion trillion} = \text{about } 2^{88}$$

Digression: powers of 2

2^{33} — humans on Earth ($\sim 8 \times 10^9$)

2^{37} — stars in the Milky Way ($\sim 10^{11}$)

2^{56} — the DES keyspace; brute-forced in 56 hours in 1998

2^{63} — grains of sand on Earth ($\sim 7.5 \times 10^{18}$)

2^{64} — wheat on the chessboard (1.8×10^{19})

2^{70} — Bitcoin network hash rate per second ($\sim 10^{21}$ H/s)

2^{76} — stars in the observable universe ($\sim 10^{23}$)

2^{92} — atoms in a human body ($\sim 7 \times 10^{27}$)

2^{128} — atoms in about 10^{10} humans (i.e., all of humanity, roughly)

2^{166} — atoms in the Earth ($\sim 10^{50}$)

2^{227} — atoms in the Milky Way ($\sim 10^{68}$)

2^{266} — atoms in the observable universe ($\sim 10^{80}$)

Digression: powers of 2

2^{16} — seconds in a day

2^{31} — seconds since 1970 (Unix time; the 2038 rollover is 2^{31})

2^{57} — seconds since Earth formed (4.5 Gyr)

$2^{58.6}$ — seconds since the Big Bang (13.8 Gyr)

2^{70} — Bitcoin network's total hashes per second

2^{90} — Bitcoin network's total hashes in 12 days

2^{128} — the entire Bitcoin network (2^{70} hashes/s) running since the Big Bang ($2^{58.6}$ s) — $2^{128.6}$

Digression: powers of 2

$2^{143.7}$ — Planck times in one second

2^{192} — Planck times in ~ 10 million years

2^{202} — Planck times since the Big Bang ($\sim 8 \times 10^{60}$)

2^{256} — every atom on Earth as a 3 GHz core, since the Big Bang

Digression: powers of 2

- 2^{368} — every atom on earth is a processor making one guess per Planck time (2^{202}) since the Big Bang
- 2^{468} — every atom in the observable universe (2^{266}) is a processor making one guess per Planck time (2^{202}) since the Big Bang
- 2^{512} — every particle in the observable universe (including CMB photons and relic neutrinos) at one guess per Planck time, from the Big Bang until the last star dies

Vigenere

S	E	N	D	R	E	I	N	F	O	R	C	E	M	E	N	T	S
V	I	G	E	N	E	R	E	V	I	G	E	N	E	R	E	V	I
N	M	T	H	E	I	Z	R	A	W	X	G	R	Q	V	R	O	A

(No Model.)

11 Sheets—Sheet 6.

J. M. E. BAUDOT.
PRINTING TELEGRAPH.

No. 388,244.

Patented Aug. 21, 1888.

Fig. 24.

	1	2	3	4	5
A	+	—	—	—	—
B	+	—	+	+	—
C	+	+	+	+	—
D	+	+	+	+	—
E	+	+	—	—	—
F	+	+	+	+	—
G	—	+	+	+	—
H	+	+	—	+	—
I	+	+	+	—	—
J	+	—	—	+	—
K	+	—	—	+	+
L	+	+	—	+	+
M	—	+	—	+	+
N	—	+	+	+	+
O	+	+	+	—	—
P	+	+	+	+	+
Q	+	—	+	+	+
R	—	—	+	+	+
S	—	—	+	+	+
T	+	—	+	—	+
U	+	+	+	—	+
V	+	+	+	—	+
W	—	+	+	—	+
X	—	+	+	—	+
Y	—	+	—	—	+
Z	+	—	—	+	+
ε	—	—	—	+	—
ν	—	—	—	—	+

INVENTOR:

Jean Maurice Emile Baudot,



One Time Ciphers

- Gilbert Vernam proposed a Vigenere cipher over a binary alphabet
 - Uses + and - modulo 2, which are both equivalent to the XOR function
 - However, Vernam's key repeats in a loop
- Joseph Mauborgne had a crucial observation
 - If the key is as long as the message and perfectly random (never re-used)
 - Then this produces an unbreakable cipher!

One Time Ciphers

- Let's imagine I've intercepted a ciphertext C
 - Now I can try deciphering under every single key...
 - What do I get?

A theorem

- A cipher is a one-time cipher (and “Shannon secure”) if
 - Given a ciphertext **C**
 - For every possible plaintext **P** (of the appropriate length),
 - There exists a key **K** that deciphers **C** to produce **P**, and...
 - The probability that **C** was generated is completely independent of the plaintext

So why don't we use one-time ciphers?

What happens if we re-use a key?

USSR
[REDACTED]

Reference: 3/NBP/T717

Issued: [REDACTED] 10/10/1955

Copy No: 205

"ALEXANDER" TO BE GIVEN NEWS OF FAMILY ON
NEXT ROUTINE TRIP TO MONTEVIDEO (1945)

From: MOSCOW

To: MONTEVIDEO

No. 31

25 January 1945

When ALEXANDER[ALEKSANDR]^[1] [next][a] pays you a regular
visit tell him that his wife and child are alive and well,
[and that][a] we are giving them the necessary help. "ALEXANDER"
may send a letter for his wife through you.

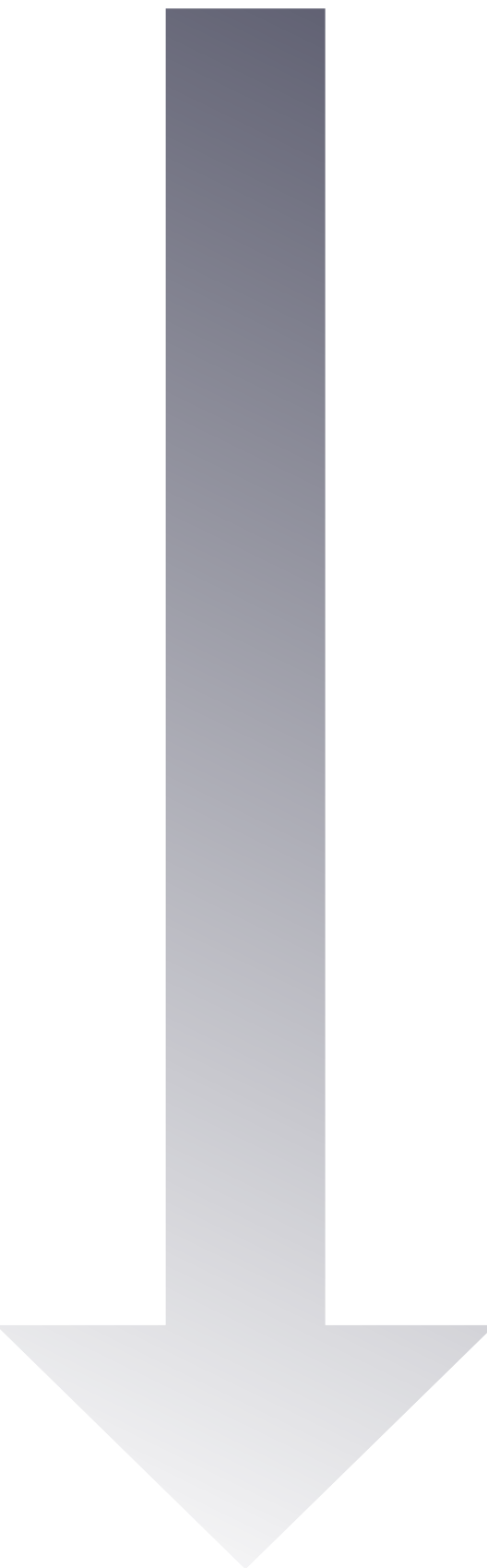
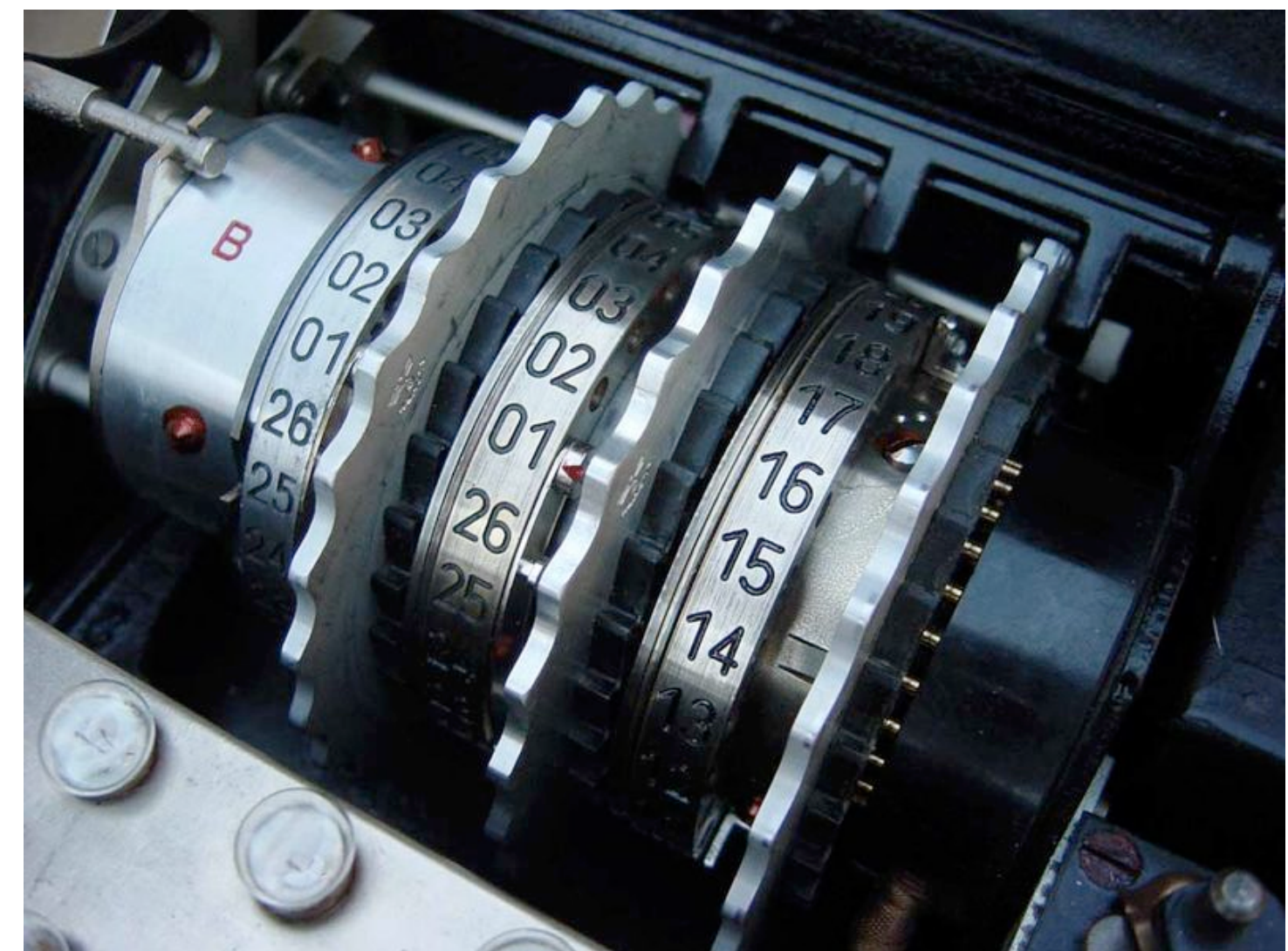
No. 475

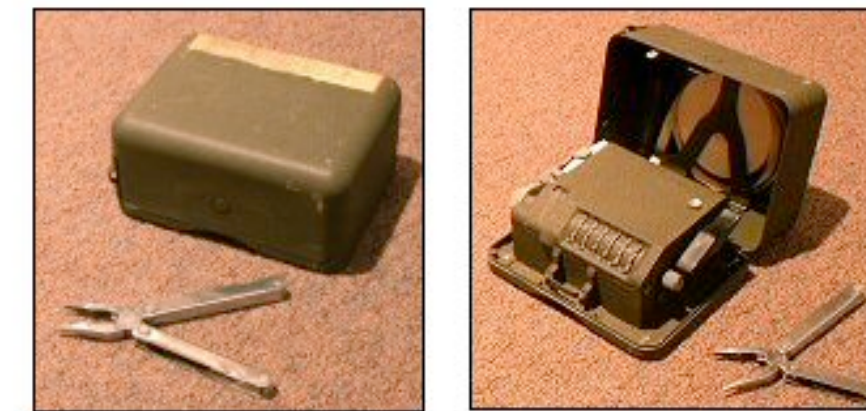
GENNADIJ^[1]

21 January

Mechanical Cryptography

- 1900s
 - Mass production and usage of cipher devices
 - Rotor ciphers
 - Electronic devices





HAGELIN M-209 CIPHER MACHINE (GVG / PD)

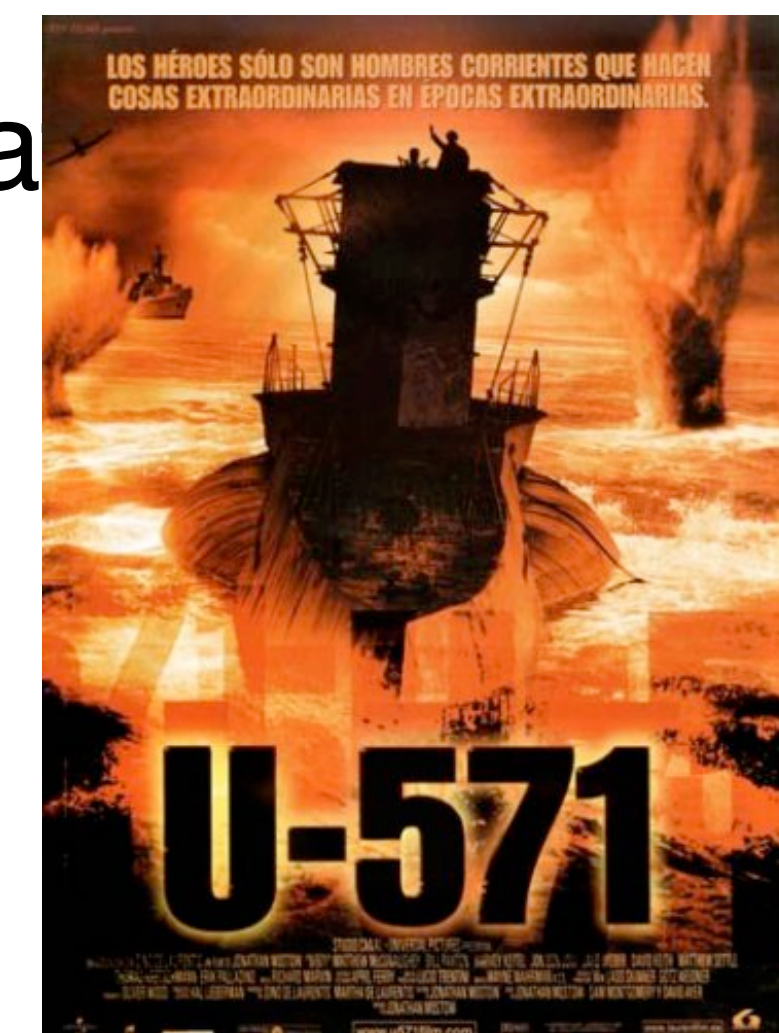
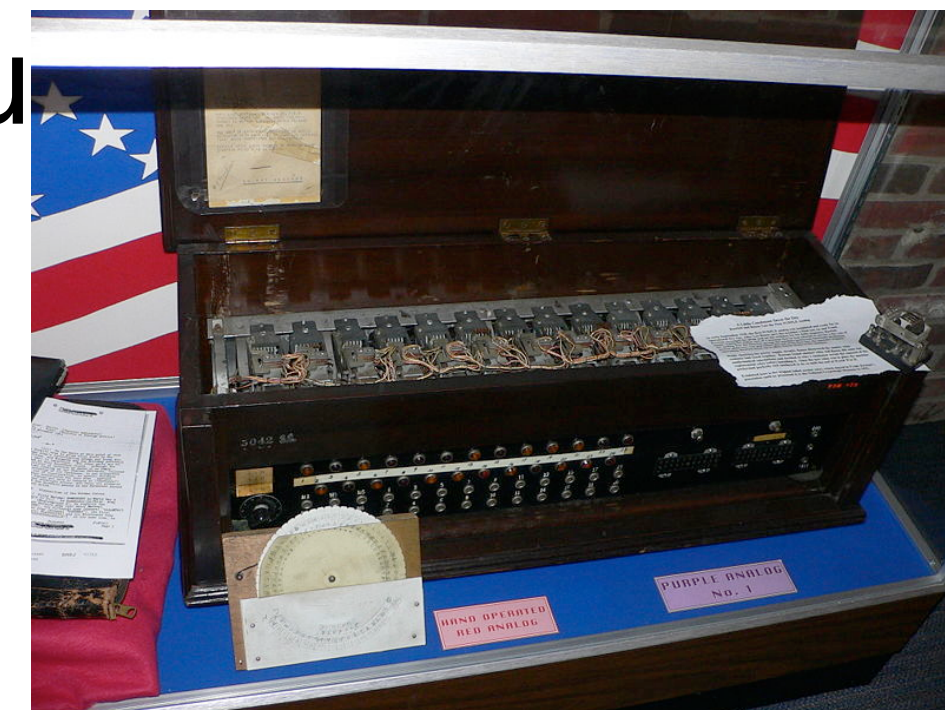




IYWJ2HOCX7PPDSE222OPXZYYXB1XFYSTT

Summary

- Most cryptosystems ultimately broken
 - Sophistication of the attackers outpaces that of the cryptosystem
 - Security relies on secrecy of design
 - Not evaluated for chosen plaintext, known plaintext a
 - Key generation/distribution procedure
 - It's an arms race...



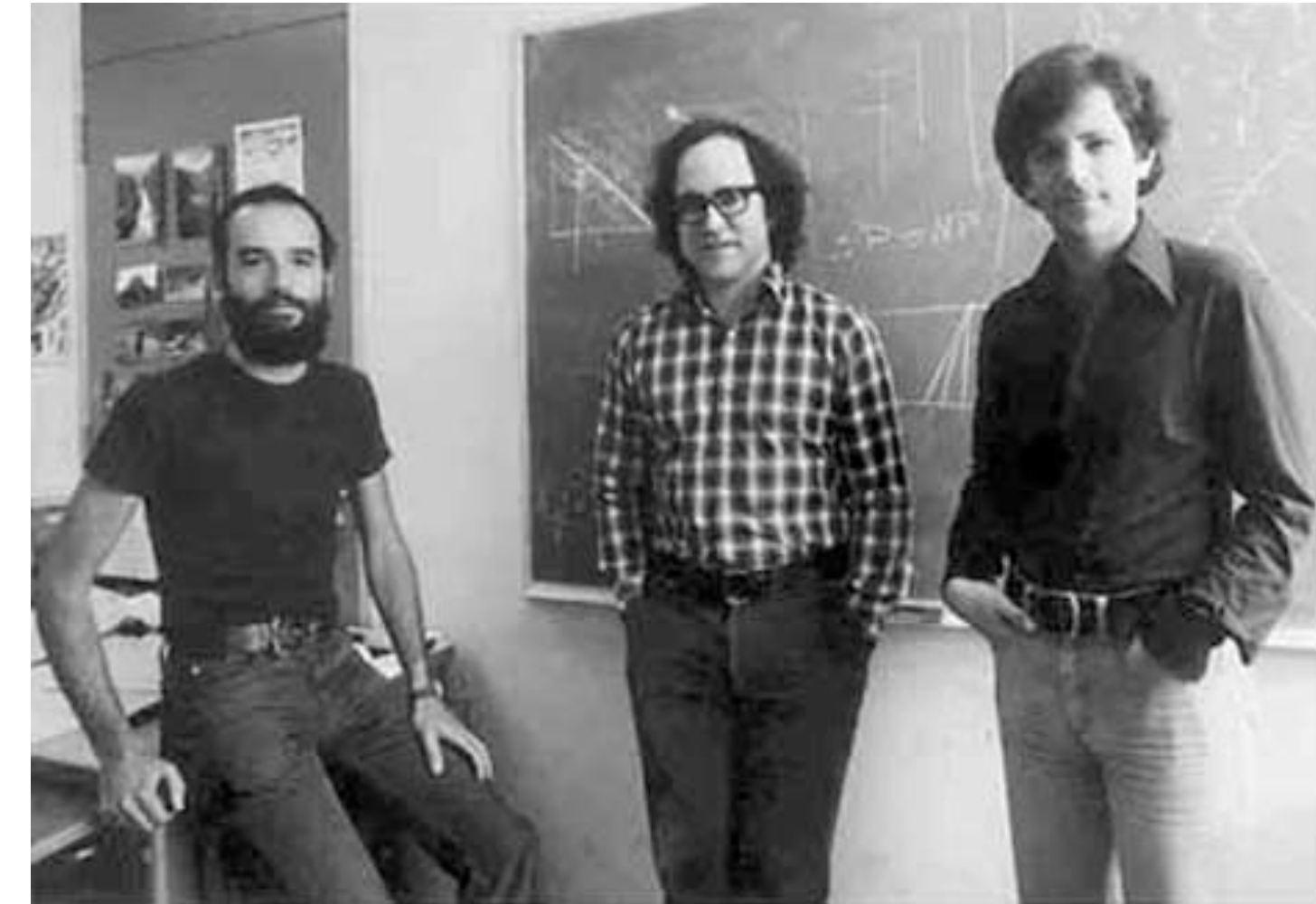
Kerckhoffs' Principle

2. It must not be required to be secret, and it must be able to fall into the hands of the enemy without inconvenience:

“The enemy knows the System”
-- Claude Shannon's Maxim



The 1970s



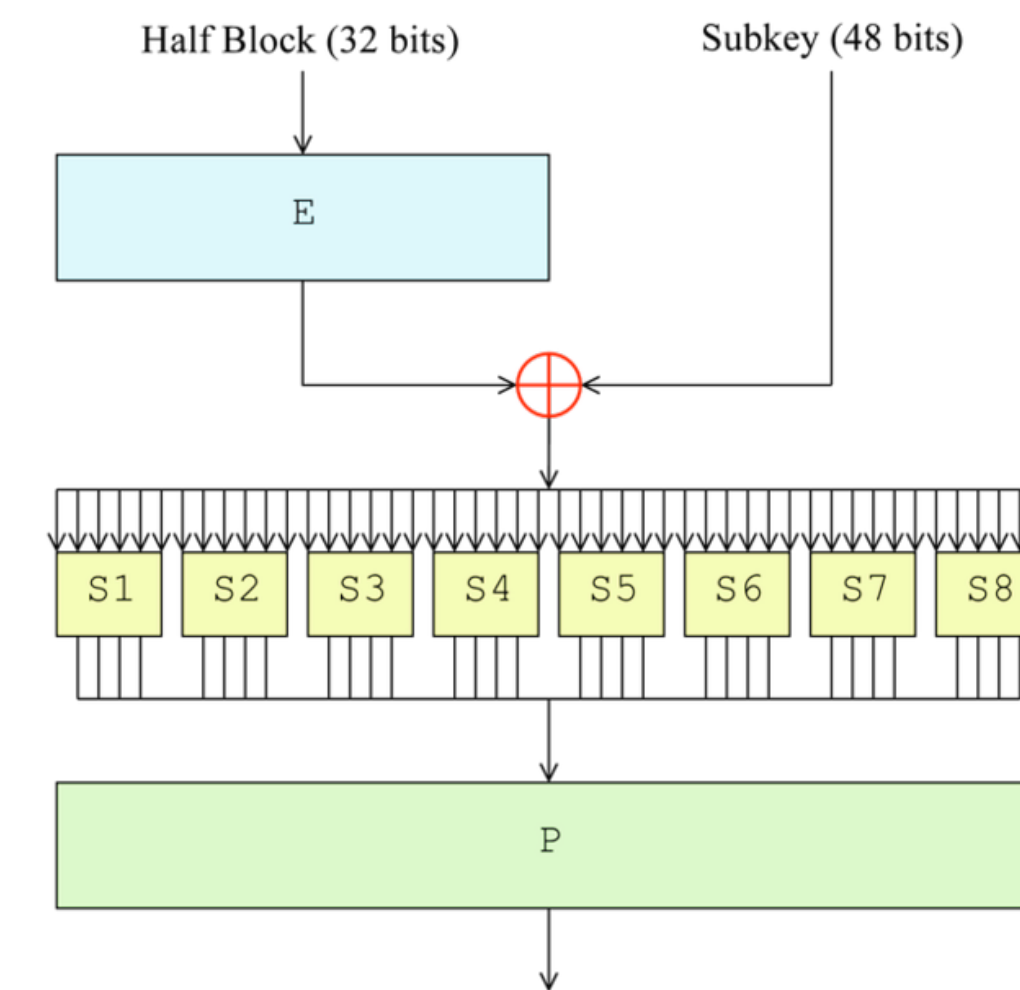
U.K. GCHQ

The Implications

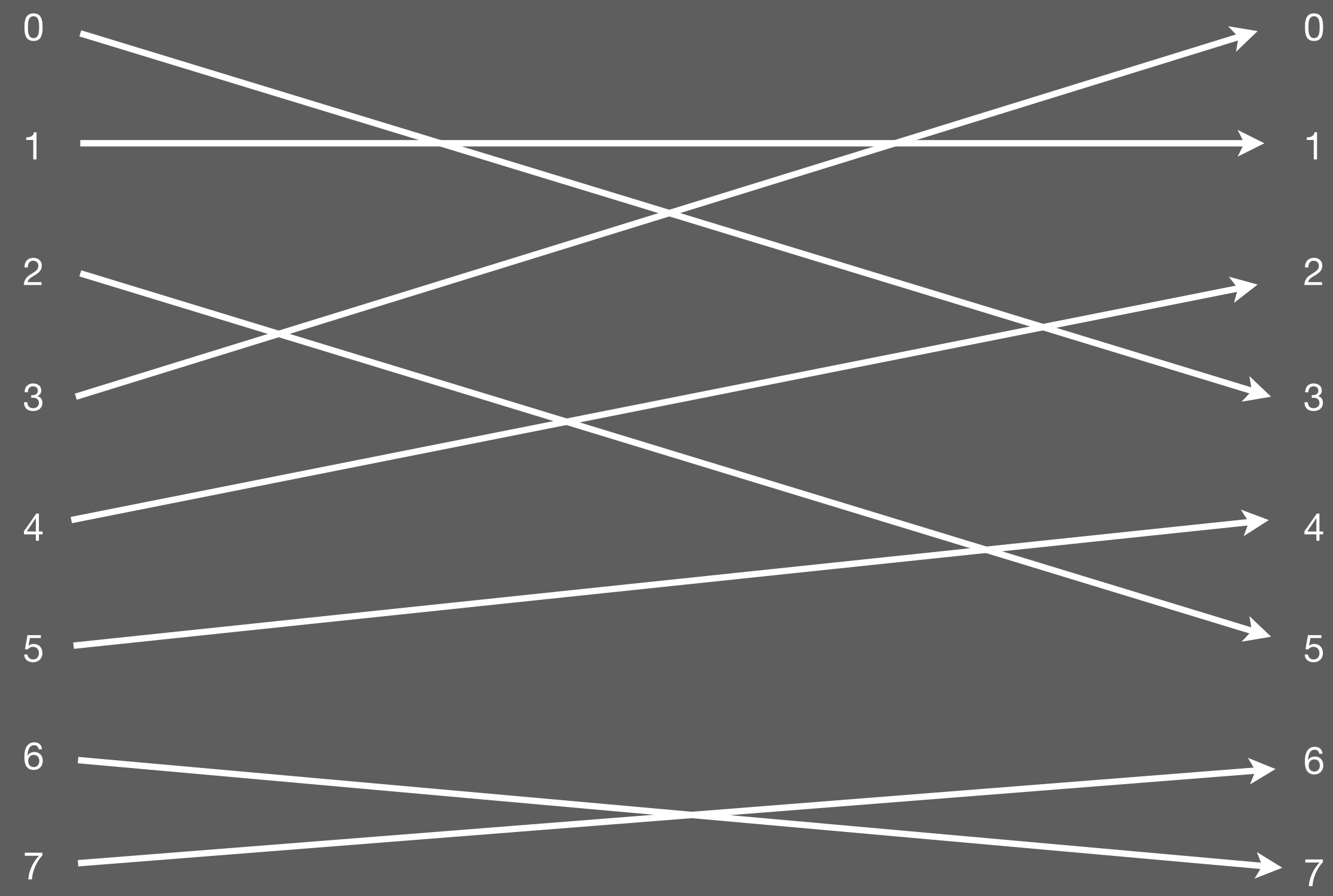
- Exponential increase in study & usage of cryptography in industry, academia
- Wide-scale deployment of cryptographic systems
- Provable Security
 - Cryptographic Systems can be reduced to some hard mathematical problem

Data Encryption Standard

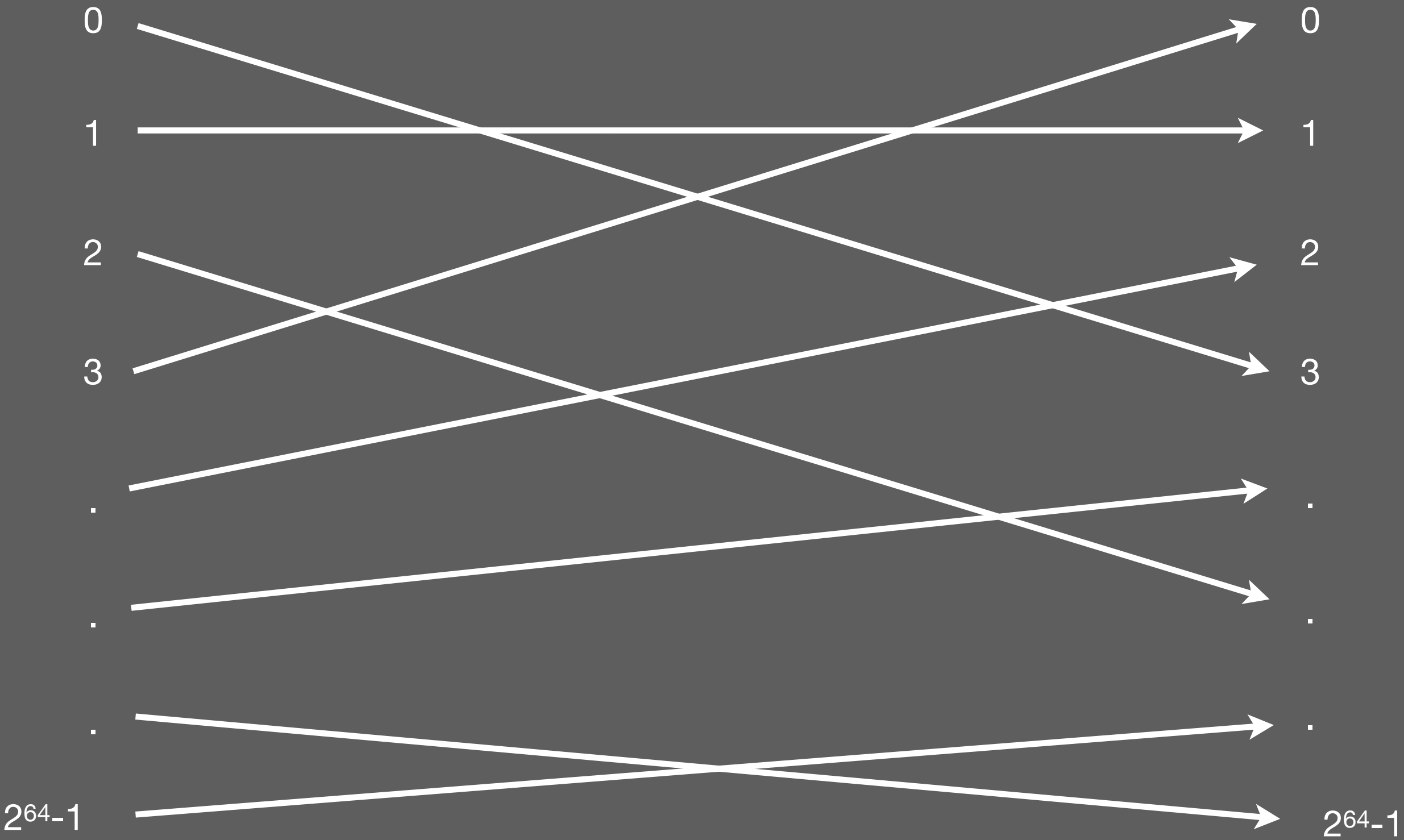
- Commercial-grade Block Cipher
 - 64-bit block size
 - 56 bit key (+ 8 bits parity)
- “Feistel Network” Construction



Permutation



Permutation



Permutation Families

- Can't have just one permutation
 - Alice & Bob know the permutation
Adversary doesn't
 - Permutation is “random” (ish)
 - But there are 2^{64} possible permutations
 - DES has a 56 bit key...

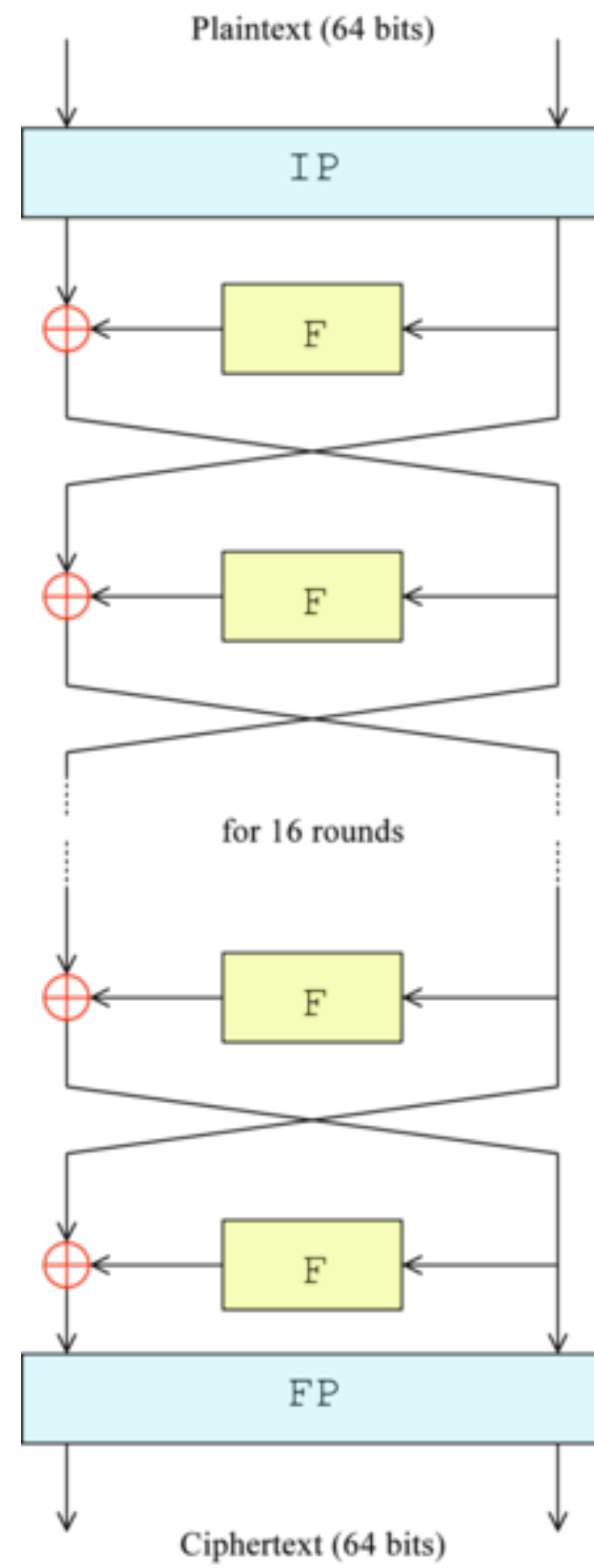
Block Cipher

- Block cipher is a family of permutations
 - Indexed by a key (DES = 56 bit key)
 - “Pseudo-random”

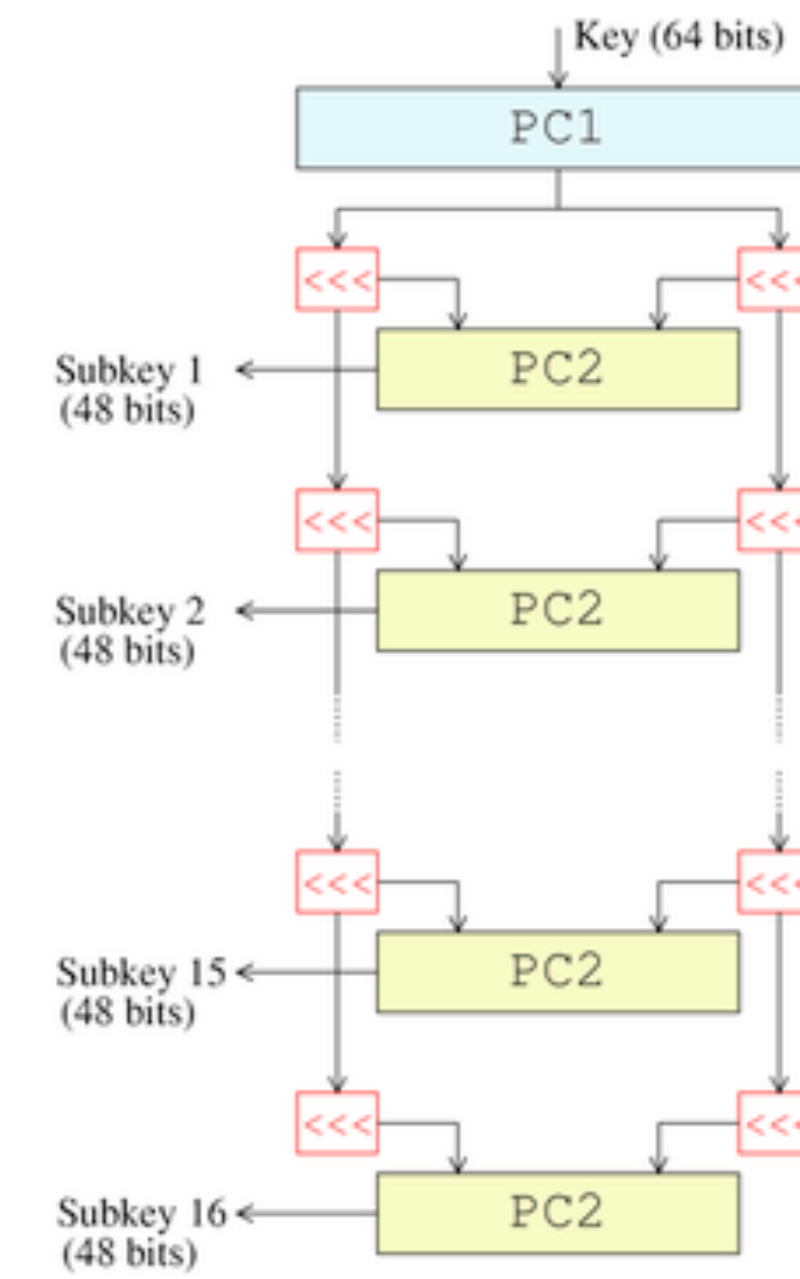
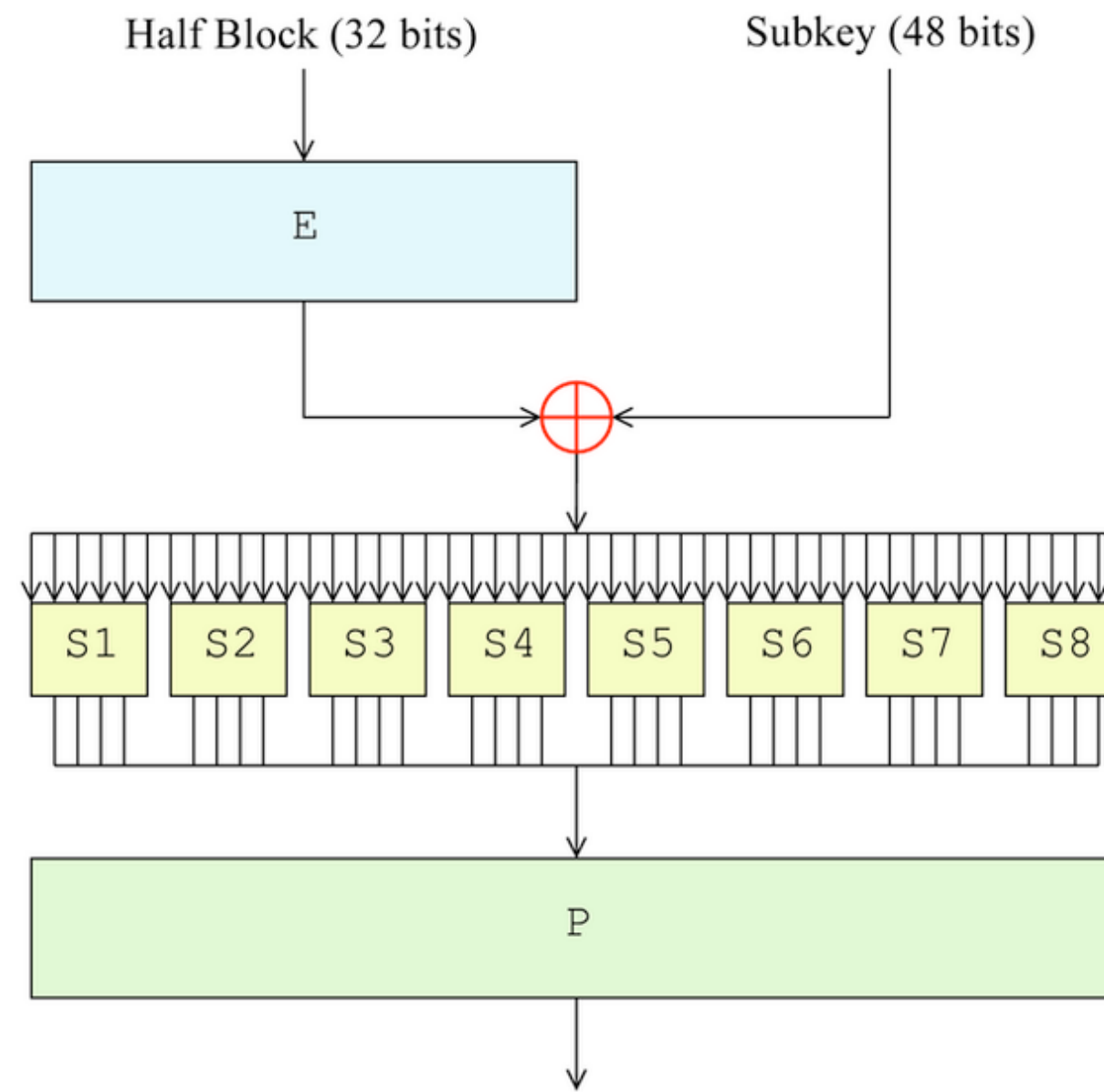
Block Cipher

- Block cipher is a family of permutations
 - Indexed by a key (DES = 56 bit key)
 - Ideally: “Pseudo-random permutation (PRP)”

(i.e., attacker who does not know the key can't determine whether you're using a random permutation, or a PRP)

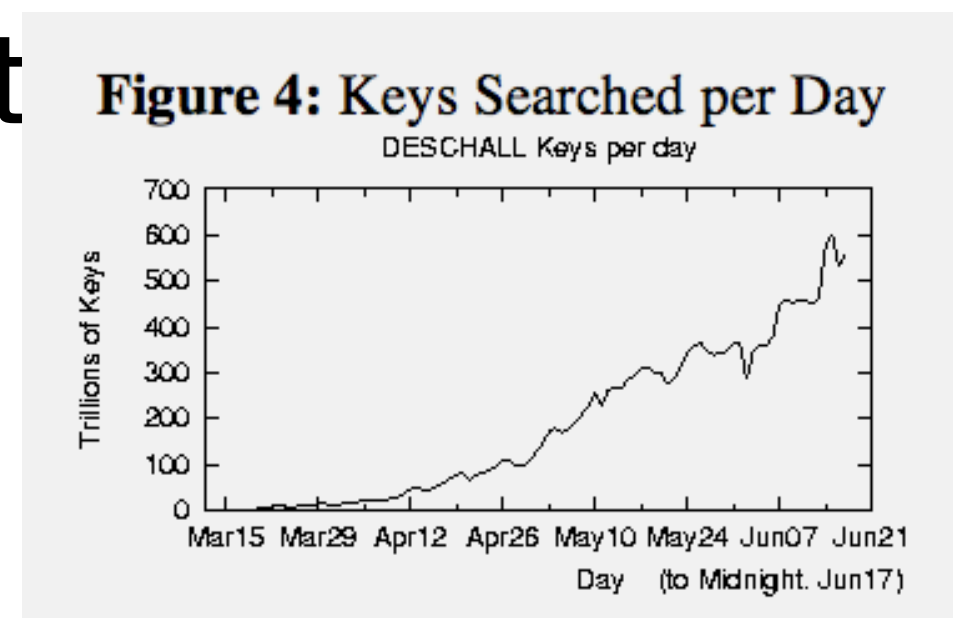


DES: 64-bit Block, 56-bit Key



DES

- Some “clever” attacks on DES
 - However: practical weakness = 56 bit key size
 - Practical weakness = 56 bit key size
 - Practical weakness = 56 bit key size
- DES (now being deprecated)



U.S. Data-Scrambling Code Cracked With Homemade Equipment

By JOHN MARKOFF

SAN FRANCISCO -- In a 1990s variant of a John Henry-style competition between man and machine, researchers using a homemade supercomputer have cracked the government's standard data-scrambling code in record time -- and have done it by out-calculating a team that had harnessed thousands of computers, including some of the world's most powerful.

